

DBMS SD Version 2.0 Diff from Review Draft

Baseline: 10dde95 - removed pdf headers / footers

Compared to: current working tree final publication source

Generated: 2026-06-24 21:22:04 UTC

+22 additions

-18 deletions

```
diff --git a/SD/DBMS_SD-working_copy.adoc b/SD/DBMS_SD-working_copy.adoc
index ec97f64..be16358 100644
--- a/SD/DBMS_SD-working_copy.adoc
+++ b/SD/DBMS_SD-working_copy.adoc
@@ -131,11 +131,11 @@ The evaluator shall check the guidance documentation to ensure that, as a minimum

```

Tests

For the events listed in the table of audit events in the ST, the evaluator shall verify the TOE's ability to correctly generate audit data and that the associated information required by the ST is included in the audit data.

-Note that the testing here may be accomplished in conjunction with the testing of the security mechanisms.

+Note that the testing here may be accomplished in conjunction with the testing of other security mechanisms.

==== FAU_GEN.2 User identity association

TSS

@@ -169,11 +169,11 @@ The evaluator shall then:

Verify that audit logs are generated for the auditable events that have been selected;

Verify that audit logs are not generated for the auditable events that are not selected.

-NOTE: The following testing may be done in conjunction with other assurance activities since auditable events occur as a by-product of the TOE being used to perform other security functions.

+NOTE: This testing may be done in conjunction with other assurance activities since auditable events occur as a by-product of the TOE being used to perform other security functions.

=== Class: User Data Protection (FDP)

==== FDP_ACC.1 Subset access control

@@ -337,11 +337,11 @@ This was performed in conjunction with FAU_SEL.1.

Tests

Testing is performed in conjunction with FAU_SEL.1.

-==== FMT_REV.1(1) Revocation

+==== FMT_REV.1(1) Revocation (Users)

TSS

The evaluator shall examine the TSS to verify that it defines the revocation rules associated with user security attributes and that the revocation rules are sufficiently described in informal language.

@@ -355,15 +355,15 @@ The evaluator shall examine the guidance documentation to verify that the user s

The evaluator shall log on as a user and verify that the user is able to perform actions in accordance with the user security attributes, specified in FMT_REV.1.1(1). If revocation is effective at the next log on then the user shall log off.

The evaluator shall log on as an authorized administrator and revoke user security attribute(s) in accordance with the guidance.

-The evaluator shall verify that the user is no longer able to perform actions in accordance with the revoked user security attributes. NOTE: any consideration of the time for the revocation to be effective shall be considered appropriately by the evaluator before completing (iii).

+The evaluator shall verify that the user is no longer able to perform actions in accordance with the revoked user security attributes. NOTE: any consideration of the time for the revocation to be effective shall be considered appropriately by the evaluator before completing the test.

NOTE: In the steps above the term “user” implies the same user throughout the test.

==== FMT_REV.1(2) Revocation (DAC)

+==== FMT_REV.1(2) Revocation (Objects)

TSS

The evaluator shall examine the TSS to verify that it defines the revocation rules associated with object security attributes and that the revocation rules are sufficiently described in informal language.

@@ -377,11 +377,11 @@ The evaluator shall examine the guidance documentation to verify that the object

* The evaluator shall log on as a user with sufficient privileges to objects according to the DAC policy and verify that the user is able to perform actions on these objects.

* The evaluator shall log on as an authorized user and revoke object security attribute(s) in accordance with the rules specified in FMT_REV.1.1(2).

* The evaluator shall verify that the user is no longer able to perform actions in accordance with the revoked object security attributes.

-NOTE: Any consideration of the time for the revocation to be effective shall be considered appropriately by the evaluator before completing (iii).

+NOTE: Any consideration of the time for the revocation to be effective shall be considered appropriately by the evaluator before completing the test.

NOTE: In the steps above the term “user” implies the same user throughout the test.

==== FMT_SMF.1 Specification of Management Functions

@@ -597,11 +597,11 @@ The evaluator shall perform the [CEM] activity as specified for ALC_DEL.2.

A DBMS is often a key component in a larger infrastructure. Therefore, the response to potential security flaws must be clearly established, and comprehensive. There must be a means of providing information and solutions to users in a timely manner, using automated means. ALC_FLR.3 has been mandated to meet these requirements.

The following table indicates, for each work unit in ALC_FLR.3, whether the [CEM] work unit is to be performed as written, or if it has been clarified by an Evaluation Activity. If clarification has been provided, a reference to this clarification is provided in the table.

-.Table 1: Mapping of ADV_ARC.1 [CEM] Work Units to Evaluation Activities

+.Mapping of ALC_FLR.3 [CEM] Work Units to Evaluation Activities

[%header,cols="1,1"]

|==

|[CEM] ALC_FLR.3 Work Units

|Evaluation Activities

|ALC_FLR.3-1 The evaluator shall examine the flaw remediation procedures documentation to determine that it describes the procedures used to track all reported security flaws in each release of the TOE.

@@ -650,11 +650,11 @@ The developer is expected to provide evidence of functional testing of the DBMS,

==== Independent Testing (ATE_IND.2)

Testing is performed to confirm the functionality described in the TSS, and that this functionality can be exercised in accordance with the guidance documentation. The focus of the testing is to confirm that

the requirements specified in the SFRs are being met. The Evaluation Activities within this document identify the specific testing activities necessary to verify compliance with the SFRs. The evaluator must produce a test report documenting the plan for and results of testing. The test report must also ensure that all the requirements of ATE_IND.2 have been met, as noted below.

-.Table 2: Mapping of ALC_FLR.3 [CEM] Work Units to Evaluation Activities

+.Mapping of ATE_IND.2 [CEM] Work Units to Evaluation Activities

[%header,cols="1,1"]	
==	
[CEM] ATE_IND.2	Work Units
Evaluation Activities	
ATE_IND.2-1 The evaluator shall examine the TOE to determine that the test configuration is consistent with the configuration under evaluation as specified in the ST.	

@@ -687,11 +687,11 @@ Testing is performed to confirm the functionality described in the TSS, and that

While vulnerability analysis is inherently a subjective activity, a minimum level of analysis can be defined and some measure of objectivity and repeatability (or at least comparability) can be imposed on the vulnerability analysis process. In order to achieve such objectivity and repeatability it is important that the evaluator follows a set of well-defined activities, and documents the findings so others can follow these arguments and come to the same conclusions as the evaluator. While this does not guarantee that different evaluation facilities will identify exactly the same type of vulnerabilities or come to exactly the same conclusions, the approach defines the minimum level of analysis and the scope of that analysis, and provides CBs a measure of assurance that the minimum level of analysis is being performed by the evaluation facilities.

In order to meet these goals some refinement of the AVA_VAN.2 [CEM] work units is needed. The following table indicates, for each work unit in AVA_VAN.2, whether the [CEM] work unit is to be performed as written, or if it has been clarified by an Evaluation Activity. If clarification has been provided, a reference to this clarification is provided in the table.

-.Table 3: Mapping of ATE_IND.2 [CEM] Work Units to Evaluation Activities

+.Mapping of AVA_VAN.2 [CEM] Work Units to Evaluation Activities

[%header,cols="1,1"]	
==	
[CEM] AVA_VAN.2	Work Units
Evaluation Activities	

|AVA_VAN.2-1 The evaluator shall examine the TOE to determine that the test configuration is consistent with the configuration under evaluation as specified in the ST.

@@ -724,27 +724,30 @@ Because of the level of detail required for the evaluation activities, the bulk

The evaluator formulates flaw hypotheses in accordance with process defined in A.6. The evaluator documents the flaw hypotheses generated for the TOE in the report in accordance with the guidelines in Appendix A.7. The evaluator shall perform vulnerability analysis in accordance with Appendix A.6. The results of the analysis shall be documented in the report according to Appendix A.7.

== References

-[CC1] Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and General Model, ISO/IEC 15408-1:2022

+ [CC1] Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and general model, CCMB-2022-11-001, CC:2022 Revision 1, November 2022

-[CC2] Common Criteria for Information Technology Security Evaluation, Part 2: Security Functional Components, ISO/IEC 15408-2:2022

+ [CC2] Common Criteria for Information Technology Security Evaluation, Part 2: Security functional requirements, CCMB-2022-11-002, CC:2022 Revision 1, November 2022

-[CC3] Common Criteria for Information Technology Security Evaluation, Part 3: Security Assurance Components, ISO/IEC 15408-3:2022

+ [CC3] Common Criteria for Information Technology Security Evaluation, Part 3: Security assurance requirements, CCMB-2022-11-003, CC:2022 Revision 1, November 2022

-[CC4] Common Criteria for Information Technology Security Evaluation, Part 4: Framework for the specification of evaluation methods and activities, ISO/IEC 15408-4:2022

+ [CC4] Common Criteria for Information Technology Security Evaluation, Part 4: Framework for the specification of evaluation methods and activities, CCMB-2022-11-004, CC:2022 Revision 1, November 2022

-[CC5] Common Criteria for Information Technology Security Evaluation, Part 5: Pre-defined packages of security requirements, ISO/IEC 15408-5:2022

+ [CC5] Common Criteria for Information Technology Security Evaluation, Part 5: Pre-defined packages of security requirements, CCMB-2022-11-005, CC:2022 Revision 1, November 2022

-[CEM] Evaluation Methodology for IT Security, ISO/IEC 18045:2022

+ [CCE] Common Criteria for Information Technology Security Evaluation, Errata and interpretation for CC:2022 (Release 1) and CEM:2022 (Release 1) CCMB-002, Version 1.1, July 22, 2024

+

+ [CEM] Common Methodology for Information Technology Security Evaluation, Evaluation methodology, CCMB-2022-11-006, CEM:2022, Revision 1, November 2022

[DBMScPP] collaborative Protection Profile for Database Management Systems, Version 2.0, 27 April 2026

[TD_DBMS_B_002] Technical Decision TD_DBMS_B_002: Session Locking Mechanism Expansion, published 29 July 2025

-Vulnerability Analysis

+ [appendix]

+== Vulnerability Analysis

=== Sources of vulnerability information

[CEM] Work Unit AVA_VAN.2-3 has been supplemented in this SD to provide a better-defined set of flaws to investigate and procedures to follow based on this particular technology. Terminology used is based on the flaw hypothesis methodology, where the evaluation team hypothesizes flaws and then either proves or disproves those flaws (a flaw is equivalent to a “potential vulnerability” as used in the [CEM]). Flaws are categorized into four “types” depending on how they are formulated:

@@ -890,17 +893,17 @@ Instructions for observing the behaviour of the TSF;

Descriptions of all expected results and the necessary analysis to be performed on the observed behaviour for comparison against expected results;

Instructions to conclude the test and establish the necessary post-test state for the TOE. (cf. AVA_VAN.2-7).

-Glossary

+= Glossary

The terms, definitions and abbreviations given in [CC1] and [CEM] apply to this document. Additional terms, definitions and abbreviations applicable are found in the DBMS cPP. In addition, the following are used in this document:

=== Terms and Definitions

-.Table 4: Mapping of AVA_VAN.2 [CEM] Work Units to Evaluation Activities

+.Terms and Definitions

[%header,cols="1,1"]

|===

|Term

|Meaning

|Administrator

@@ -913,10 +916,11 @@ The terms, definitions and abbreviations given in [CC1] and [CEM] apply to this

|A means of restricting access to objects based on the identity of subjects and/or groups to which they belong. Those controls are discretionary in the sense that a subject with certain access permission is capable of passing that permission (perhaps indirectly) on to any other subject.

|===

=== Acronyms used in this SD

+.Acronyms used in this SD

[%header,cols="1,1"]

|===

|Acronym

Meaning
CB